

OWASP ZAP - Instalación y Configuración

Guía completa para preparar el entorno, instalar, configurar, validar y realizar el primer uso funcional de la herramienta.

Objetivo del manual

Este manual fue desarrollado para orientarle durante todo el proceso de instalación y configuración de la herramienta, desde la preparación del entorno hasta la validación final. Siga las etapas en el orden presentado y utilice las verificaciones indicadas para confirmar que cada configuración fue concluida correctamente.

Referencias oficiales

<https://www.zaproxy.org/download/>

Qué es OWASP ZAP

ZAP es un proxy de seguridad open source que permite observar y manipular tráfico HTTP/HTTPS y apoyar pruebas dinámicas de aplicaciones Web.

Passive Scan

Passive Scan analiza el tráfico que pasa por ZAP sin atacar activamente el objetivo. Puede señalar headers, atributos de cookies, mixed content y otras señales observables de seguridad. Es un buen punto de inicio porque tiene menor riesgo de modificar el estado de la aplicación.

Active Scan

Active Scan envía requests diseñados para investigar posibles vulnerabilidades. Es intrusivo y puede modificar datos o afectar disponibilidad; úselo solo contra objetivos explícitamente autorizados y ambientes controlados, con alcance, credenciales y condiciones de parada acordadas.

Quick Start y proxy

Use Quick Start para una exploración guiada o configure navegador/aplicación para enviar tráfico por ZAP. Confirme alcance, manejo de certificados HTTPS y autenticación antes de escanear. Comience navegando y revisando hallazgos pasivos antes de acciones más invasivas.

QA y DAST en CI

ZAP puede apoyar checks DAST automatizados en CI/CD, pero el pipeline debe definir objetivo, autenticación, política baseline, riesgo aceptado y criterios de fallo. Trate los hallazgos como entradas para triage y no como vulnerabilidades confirmadas automáticamente; correlacione evidencia y revisión de seguridad.

Punto de atención

Las pruebas de seguridad requieren autorización. Nunca ejecute scans activos contra producción, terceros o ambientes fuera del alcance acordado. Proteja credenciales y tráfico capturado, evite datos sensibles en reportes e involucre especialistas de seguridad en hallazgos de alto impacto.